

Insider Data Exfiltration response

Data Exfiltration · **High** severity · SOC IR Playbook

Incident type	Insider Threat - Data Exfiltration
Severity	High
Priority	High to Critical
Detection sources	DLP, SIEM, Proxy logs, CASB, EDR, Email gateway

Scenario

An internal employee, contractor or privileged user attempts to or successfully exfiltrates sensitive data through unauthorised channels such as personal email, cloud storage, removable media or file transfer tools.

MITRE ATT&CK

T1020, T1048, T1537

Preparation

Define sensitive data categories Classify files: PII, financial data, trade secrets DLP implementation Set detection policies on endpoints, network, email Activity monitoring Log user access, file transfer and cloud app usage Insider risk training Educate employees about acceptable data handling Access control enforcement Role-based access, least privilege, segmentation

Detection & Analysis

Trigger detection alert DLP violation, abnormal download, large email attachments, unusual file uploads Analyse access logs Look for file access, transfer times and destinations Investigate user behaviour Check for privilege escalation, login time anomalies, failed access attempts Confirm intent or misconfiguration Determine if action was malicious, accidental or a policy gap

Containment

Suspend user access Temporarily disable account if risk is high Block exfiltration channels Revoke cloud sharing, block email to external domains, disable USB ports Isolate endpoints If malicious software is suspected on the user device Preserve forensic evidence Do not shut down systems unless necessary; capture volatile data if possible

Eradication

Remove unauthorised tools E.g., personal file transfer apps, rogue extensions Apply stricter policies Adjust DLP rules or firewall rules to block repeat attempts Correct misconfigured permissions Reduce overexposed data shares, folder-level access

Recovery

Restore access (if justified) After confirming no ongoing threat Notify stakeholders Legal, HR, compliance and management teams Conduct impact assessment Confirm if data was actually exfiltrated and its sensitivity

Lessons Learned & Reporting

Document the incident Timeline, data types, actor intent, system used Strengthen monitoring Improve alerting on specific file types and transfer methods Conduct user training or disciplinary action If incident is confirmed malicious or negligent Report to regulators If required by law (e.g., PDPA, GDPR, HIPAA) Update insider threat policy Incorporate new insights into security procedures

Tools typically involved

SIEM (e.g., Splunk, IBM QRadar, Microsoft Sentinel); DLP systems (e.g., Symantec, Forcepoint, Microsoft Purview); CASB (e.g., Netskope, Microsoft Defender for Cloud Apps); Endpoint agents (e.g., EDR with data transfer monitoring); Proxy & firewall logs; Email Security Gateway (e.g., Proofpoint, Mimecast)

Success metrics (SLA targets)

Detection Time <10 minutes from data transfer Investigation Time <1 hour from alert Containment Time <30 minutes Regulatory Response Time Within required legal timeframe (e.g., 72 hours)

XORCISM SOC Incident-Response Playbook 2 of 42 · PICERL lifecycle · Adapted from the community SOC IR Playbook library (github.com/okanyildiz/cybersecurity-notes)